CASE STUDY

# Able2Shell and the RMM Attack Surface: The N-able N-central Disclosure of November 2026

*A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.*

## Executive summary

Managed service providers (MSPs) look after the IT of thousands of small and mid-sized organizations at once, and the tool they do it with is a remote monitoring and management (RMM) platform: one server that holds an agent on every managed laptop, server and domain controller and can push scripts, software and remote sessions to all of them. That is why defenders, and the people who attack them, treat an RMM server as one of the most valuable hosts on any network it touches. When the RMM server falls, every customer behind it is exposed, as Kaseya's customers learned in July 2021 (**Confirmed** [44] [45]).

N-able N-central is one of the larger RMM platforms; N-able says it serves more than 25,000 MSP partners and takes telemetry from more than 11 million endpoints (**Reported**, vendor claim relayed by CSO [32]). Late on Sunday 8 November 2026, US time, a researcher's GitHub account published a folder of 33 alleged N-central vulnerabilities, grouped into four exploit chains, with a proof-of-concept script for each and no advance notice to the vendor by the researcher's own account (**Confirmed** for the commit time [14] [15]; **Reported** for the substance [14] [25]). The security press and the defender community soon called it Able2Shell [16] [17] [22]. Within hours N-able took its whole hosted N-central service offline in the Americas, Europe and Asia-Pacific and told on-premises customers to disconnect their servers (**Confirmed** [1]). On 10 November it shipped N-central 2026.4 Hotfix 2 (build 2026.4.1.26) and published seven CVE records, two of them rated CVSS v4.0 9.3 with no privileges needed (**Confirmed** [2] [4] [5]). By the status update stamped 2026-11-11 01:04 (dashboard time; the press dates it to 10 November) every hosted server had been upgraded (**Confirmed** [1]).

What makes Able2Shell a case study is not one bug. It is the collision of three things the record shows plainly: an RMM product line that already had five entries in CISA's Known Exploited Vulnerabilities (KEV) catalog,

three of them from August and September 2026 (**Confirmed** [12]); a full public disclosure with proof-of-concept code that the vendor called "non-responsible" and the researcher called a response to earlier reports left unpatched (**Reported** [28] [26]); and a gap between the headline ("33 zero-days") and the vendor record (seven CVEs, not mapped to the 33 findings) that every defender had to work through while the service was down (**Confirmed** [2] [3]; **Reported** [16]). As of 11 November 2026 the activity seen after the drop is scanning, probing and attempts against honeypots and decoys; no source confirms a customer compromise through Able2Shell (**Inferred** from [3] [17] [18] [19] [23]).

This is not a lab study. N-central is a commercial appliance with no free image, so nothing was reproduced. The published proof-of-concept scripts were never opened, downloaded, quoted or run, and no command line, payload or exploit detail appears here; the four chains are named only by vulnerability class and resulting privilege, as Tenable's FAQ and the CVE titles name them; the vulnerabilities are described at the level the vendor's CVE records and the defender advisories use.

## Key facts at a glance

| Field | Value |
|---|---|
| Product | N-able N-central, an RMM platform for MSPs, sold as a hosted service (N-central hosted, "NCOD") and as a self-hosted appliance [1] [2] |
| Name | Able2Shell, as Tenable, Huntress and the H-ISAC bulletin title it [16] [17] [22] |
| Publication | Commit "N-Able 0-Days" to the researcher's GitHub repository, 2026-11-09 04:14:21 UTC, which is late on 8 November in the continental US time zones (**Confirmed** [14] [15]; reconciliation **Inferred**) |
| Researcher's claim | 33 findings in the README index, four named exploit chains, one proof-of-concept script per finding, all tested on N-central Appliance 2026.4.0.31, which the researcher calls pre-release (**Reported** [14] [16]) |
| Vendor fix | N-central 2026.4 Hotfix 2, build 2026.4.1.26, posted 2026-11-10; removes legacy MDM and temporarily disables built-in remote control [2] |
| CVE records | Seven, CNA N-able, published 2026-11-10 between 21:19 and 21:26 UTC: CVE-2026-125878 to CVE-2026-125883 and CVE-2026-91000; CVSS v4.0 from 8.3 to 9.3; affected "before 26.4.1" [4] to [10] |
| Hosted takedown | Status incident from 2026-11-09 14:00 (dashboard time), hosted and on-premises N-central in three regions, "Major Outage" [1]; all hosted servers upgraded by the 2026-11-11 01:04 status update [1] |
| Exploitation | Scanning tied to the public code (vendor) [1] [3]; attempts against honeypots and decoys (watchTowr via Beazley; Previdian) [18] [19]; no confirmed customer compromise as of 2026-11-11 [3] [17] [18] |
| CISA KEV | None of the seven, catalog version 2026.11.10 [12]; five earlier N-central CVEs listed, all ransomware use "Unknown" [12] |
| CISA SSVC | CVE-2026-125883: Exploitation poc, Automatable yes, Technical Impact total [4] |
| Attribution | None: Tenable says no threat actor had been linked to Able2Shell as of 10 November [16] |
| Internet exposure | Shadowserver: 1,338 servers on 9 November, just over 148 by 11 November (BleepingComputer) [26]; Censys: 1,728 (The Hacker News, CSO) [30] [32]. Separate measurements, not to be combined |

## Key findings

- **The vendor treated it as critical before the CVEs existed.** N-able took hosted N-central offline in every region from 9 November and told on-premises customers to stay offline until upgraded (**Confirmed** [1]). Taking a whole hosted fleet down within hours is the strongest severity signal in the record (**Inferred**).
- **"33 zero-days" is the researcher's count, not the vendor's.** The README lists 33 findings; N-able published seven CVEs, has not mapped them to the 33 findings, and has not said how many it could reproduce (**Confirmed** [2] [3]; **Reported** [16] [32]). One of the seven, CVE-2026-125882, is credited to a different researcher, Nate Fair of Sprocket Security (**Confirmed** [8]).
- **Part of the fixed batch predates the drop.** CVE-2026-91000 was reserved on 14 September 2026, eight weeks before the publication; the other six were reserved on 10 November (**Confirmed** [10] [4]).

- **N-able says every unauthenticated path is closed.** Its 11 November update says all identified vulnerabilities an unauthenticated user could exploit are fixed in HF2 and that the remaining ones need an authenticated, often privileged, account and will follow in later hotfixes (**Confirmed** as the vendor's statement [3]; not independently tested).
- **Attempts, not compromise.** N-able reports scanning tied to the published code; watchTowr reported exploitation attempts against its honeypots overnight; Previdian's decoy logged 68 events from one source address, with no account takeover and no command execution (**Confirmed** [1]; **Reported** [18]; **Demonstrated** [19]). Huntress found no Able2Shell exploitation in partner environments (**Confirmed** [17]).
- **The product line is a proven target.** KEV lists CVE-2025-8875 and CVE-2025-8876 (added 13 August 2025), CVE-2026-18577 (3 August 2026), CVE-2026-18556 (4 August 2026) and CVE-2026-86218 (8 September 2026) (**Confirmed** [12]). In the summer 2026 intrusion, an attacker used N-central's own Take Control feature to reach managed devices and registered Cloudflare tunnel services for persistence (**Confirmed**, N-able's account [37]).
- **The disclosure is disputed on the record.** The researcher says he gave no notice because earlier reports on a different N-able product went unpatched for five to six months (**Reported** [25] [26]); N-able calls claims that it ignored responsible disclosure "inaccurate" and says the 9 November findings did not come through its reporting channels (**Confirmed** as the vendor's statement [3]).

## Top recommendations

1. Keep every self-hosted N-central server off the network until it runs 2026.4 HF2 (2026.4.1.26) or later, then upgrade Agents first and Probes second, because an upgraded Probe cannot talk to Agents that are not upgraded [1] [2].
2. Take the N-central management interface off the internet for good: restrict it to an administrative VLAN or VPN [23] [20] [21].
3. Hunt from 8 November 2026 onward for new administrator accounts, newly deployed scripts, anomalous remote-control sessions and automation policy changes, and watch managed endpoints for unexpected child processes and silent installs by the agent [17] [23].
4. Treat the server as a credential store: preserve logs and snapshots first, then rotate administrator, technician and asset-discovery credentials, agent registration tokens and ecosystem agent keys, and inventory what the server can reach (domain controllers, hypervisors, backups, identity providers) [32] [20] [23].
5. Plan for more than one hotfix. N-able says authenticated issues remain and a follow-up hotfix is coming [1] [3]; watchTowr warned that HF2 may not be the last [33].
6. Govern RMM as a privileged path, not a utility: allowlist the approved RMM, require MFA on privileged and remote-access accounts, allow RMM only over approved remote access, and keep MSP accounts out of customer administrator groups [46] [56].

## Scope and method

This study covers the Able2Shell publication of 9 November 2026 and the vendor, CVE, KEV and defender record up to 11 November 2026, framed by the RMM attack surface: Kaseya VSA in 2021, ConnectWise ScreenConnect in 2024, SimpleHelp in 2025 and the earlier N-central KEV entries of 2025 and 2026. Kaseya's home study in this library is Chronicle 2021; this study summarizes it in one paragraph and links it.

Handling rule: from the researcher's repository, only the account and repository metadata, the commit history, the file names and the README prose were read. The 33 proof-of-concept scripts were counted by name from the folder listing and never opened, downloaded, quoted or run [14]. Network indicators that Beazley and others publish are not reproduced [18]. Every web source was opened on 11 November 2026. Quotations are kept under 15 words.

Several primaries could not be opened, and claims that depend on them are graded from the secondary sources that quote them: N-able's per-CVE security advisory pages on its customer portal (a JavaScript application with no readable text); N-able status event 202561, which the press cites for the 9 November alert (the event API refused the request); the HF2 release note on documentation.n-able.com (HTTP 403; the same note was read on status.n-able.com [2]); watchTowr's own statement; Defused's own statement; the Censys and Shadowserver primaries for the exposure counts; and the Cloud Security Alliance's dedicated research note (HTTP 404).

Where sources disagree, the study says so. The vendor's status dashboard is the primary record for N-able's statements; its time stamps carry no time zone in the data, so they are given as "dashboard time" [1].

| Grade | Meaning |
|---|---|
| Confirmed | Taken from a primary source that was opened: N-able's status page, release notes and blog, the CVE records, NVD, CISA (KEV, advisories, guidance), the H-ISAC bulletin, a government CERT, or the repository metadata observed directly. A vendor's statement about itself is Confirmed as that vendor's statement |
| Reported | A secondary account, attributed: press coverage, a security vendor relaying someone else's observation, or the researcher's own claims about the findings |
| Demonstrated | Telemetry published by the party that observed it on its own sensor or decoy |
| Inferred | This study's own reading of the cited facts, labelled as such |

# Part 1: The disclosure record

## The publication

A request to GitHub for the repository the press names, Oracle-Security/CVEs, is answered on 11 November 2026 by MSPNightmare/CVEs: owner login MSPNightmare, account created 13 January 2023, repository created 13 April 2023, description "All of my exploits :)" (**Confirmed** [14]). Requests for the Oracle-Security repository now resolve to the MSPNightmare account, which is consistent with an account rename or a repository transfer (**Confirmed** for the redirect [14]; **Inferred** for its cause). The N-central material sits in a folder named "0-Days/N-Central N-Able", added in a single commit titled "N-Able 0-Days" at 2026-11-09 04:14:21 UTC (**Confirmed** [14] [15]). A second commit at 21:49:52 UTC the same day added a README disclaimer that the author is not affiliated with Vector 35 or its BinaryNinja product (**Confirmed** [14] [15]).

The time stamp settles a small conflict in the press. BleepingComputer, TechTarget and SecurityWeek date the disclosure to late Sunday 8 November; Tenable, Huntress and H-ISAC date it to 9 November; GovInfoSecurity says it was posted on Monday (**Reported** [25] [27] [29] [16] [17] [22] [28]). 04:14 UTC on 9 November is 20:14 to 23:14 on Sunday 8 November across the continental US time zones, so all of them describe the same moment: the US outlets give US local time, and Tenable, Huntress, H-ISAC and GovInfoSecurity's "Monday" give the UTC date (**Inferred** [14] [25]).

## What the README claims

The README's vulnerability index lists 33 findings, and the folder holds 33 proof-of-concept script files and a screenshots folder (**Confirmed** for the count by file name [14]). Whether each finding is a real vulnerability is the researcher's claim (**Reported** [14]). The README says all testing was done on "N-able N-central Appliance 2026.4.0.31", calls that a pre-release version, says most if not all findings should work on earlier versions including the current release, and says every finding was unpatched when posted (**Reported** [14] [16]).

The README names four exploit chains. At the level of vulnerability class and resulting privilege, they are (**Reported** [14]):

1. An anonymous XML external entity (XXE) flaw in service import, leading to code execution as the appliance's service account, `nable`. The README claims this chain can also create an enabled administrator account.
2. An anonymous stored cross-site scripting (XSS) entry in MMS3 patch metadata, leading to OGNL expression execution as `nable` once an administrator views the patch.
3. The same stored XSS entry, leading to code execution as root through the Audit Export feature.
4. An authenticated path traversal to the `nable` account, followed by a local privilege escalation through a root-owned helper to root.

Tenable's reading of the same README: one chain needs no credentials, two need no login to plant the payload but need an administrator to view it, one needs a login, and two of the four reach root (**Reported** [16]).

Beyond the chains, the README index names a wide spread of classes (**Reported** [14]): XXE (three entries), OGNL expression injection, stored XSS, path traversal and arbitrary file write, option and grammar injection in the backup-restore, test-email and Audit Export features, local privilege escalation through root helpers, a native stack overflow in a GenericTCP component, a cluster of authorization and identity confusions

(appliance registration confusing customer and appliance, Technician account creation, registration-token disclosure, a view-only role able to write configuration, an MMS2 session and object mismatch, policy disclosure to a zero-role user), credential disclosure (asset-discovery database credentials and Ecosystem Agent credentials), cross-customer appliance disclosure, global configuration overwrite, MDM device impersonation, remote-control session termination and audit-record overwrite, a predictable MMS3 passcode, and account enumeration through password reset. Server-side request forgery (SSRF) is not a README heading; it appears only as a vendor CVE class (CVE-2026-125881) [5].

The spread matters more than any single entry. Several of these classes (cross-customer disclosure, Technician account creation, registration-token disclosure, view-only roles writing configuration) are about the boundaries between MSP staff roles and between one MSP customer and another, which is exactly the boundary an RMM platform exists to enforce (**Inferred** from [14]).

### Who published it

The press does not agree on who the researcher is. BleepingComputer, GovInfoSecurity (which calls him an application security consultant), SecurityWeek and The Hacker News name the researcher. BleepingComputer says he disclosed through a LinkedIn post and the GitHub repository, and it links the Oracle-Security repository without saying the account is his (**Reported** [25] [28] [29] [30]). TechCrunch prints a different first name (**Reported** [31]). Because the press disagrees, this study does not repeat the name. TechTarget says the repository belongs to a researcher using the handle "BinaryNinja" and gives no name (**Reported** [27]), which may explain the disclaimer about Vector 35's BinaryNinja product added the same day (**Inferred** from [14] [27]). Tenable and the H-ISAC bulletin name only the GitHub account; runZero says the link between the researcher and N-able's status event is likely but unconfirmed (**Reported** [16] [22] [21]). This study refers to the researcher by the account as published.

The researcher told BleepingComputer that the discovery was AI-assisted (**Reported** [25]), and that after the drop N-able's chief executive and chief technology officer contacted him, asked him to take the repository down and work with the company, and did not threaten him (**Reported** [25]).

## Part 2: The vendor and CVE record

### The status page

N-able's status dashboard carries incident 202584, "N-central Critical Security Incident", starting 2026-11-09 14:00 (dashboard time), with six affected services: N-central hosted and N-central on-premise, each in the Americas, APAC and Europe; severity "Major Outage", status "Monitoring", no end time when read on 11 November (**Confirmed** [1]). The incident text attributes the event to the public disclosure of critical N-central vulnerabilities by an independent security researcher; it does not name the researcher or say whether N-able had notice (**Confirmed** [1]).

The status page's account of the response, in order (**Confirmed** [1]):

- Hosted environments "had previously been taken offline as a precaution" while remediation was developed and validated. Huntress dates the hosted takedown to 9 November (**Reported** [17]).
- On-premises customers were told to keep servers offline while remediation was developed; the current wording is that servers should stay offline until successfully upgraded.
- The release addressing "the most critical November 9 vulnerabilities" became available.

- N-able is observing scanning activity associated with the published proof-of-concept code.
- A follow-up hotfix will provide further security updates; no date is given.
- An update at 2026-11-11 01:04:27 (dashboard time) says all hosted N-central servers (NCODs) in all global regions were upgraded, including Trial participants. The press dates the same statement to 10 November (**Reported** [26] [16]), which fits if the dashboard runs on UTC (**Inferred**).

The press quotes the original 9 November alert, which the status page no longer shows: GovInfoSecurity quotes it as describing "a public disclosure and non-responsible communication of critical vulnerabilities in N-central", taking the hosted environment offline as a precaution and telling on-premises customers to take servers offline until further notice (**Reported** [28]). GovInfoSecurity puts the declared incident ("major outage") at 15:15 UTC on 9 November; Beazley says hosted N-central was offline from 14:00 UTC; services reached through N-able Login (the Ecoverse) stayed up (**Reported** [28] [18]). The 14:00 start on the status dashboard matches Beazley's time if the dashboard is on UTC (**Inferred** from [1] [18]).

## N-central 2026.4 Hotfix 2

The HF2 release notes, posted on N-able's status site on 10 November 2026, describe build 2026.4.1.26 as a critical security update that supersedes 2026.4 (build 2026.4.0.27) and 2026.4 Hotfix 1 (build 2026.4.0.32) (**Confirmed** [2]). The hardening it lists: authentication and permission checks, file upload and log handling validation, server hardening, Agent and Probe communication, web and sign-in protections, and operating-system and third-party component updates (**Confirmed** [2]).

Two product changes in HF2 do not show up in any CVE list (**Confirmed** [2]):

- **Legacy mobile device management (MDM) is removed.** The README lists an MDM device impersonation finding [14]; removing the feature removes that surface outright (**Inferred**).
- **Built-in remote control is temporarily disabled**, to be re-enabled in a future fix; Take Control keeps working [2].

The upgrade itself has an order. N-able upgrades hosted servers; on-premises customers upgrade their own servers as soon as possible. All customers, hosted and on-premises, must then upgrade Agents first and Probes second: a Probe on 2026.4.1.26 cannot communicate with Agents (or the PME component) that have not been upgraded (**Confirmed** [2]). Supported direct upgrade paths start at 2025.4 (2025.4, 2026.1, 2026.2, 2026.3, 2026.3.1 with Hotfixes 1 to 4, 2026.4 and 2026.4 HF1); older servers must first move to a supported build (**Confirmed** [2]).

The researcher's tested build, 2026.4.0.31, sits between the 2026.4 general-availability build (2026.4.0.27) and HF1 (2026.4.0.32) in N-able's own numbering, which is consistent with the researcher's "pre-release" label (**Inferred** from [2] [14]). It does not narrow the seven CVEs: their records say N-central before 26.4.1 is affected (before 2026.4.1 for CVE-2026-91000) [4] to [10]. No opened source establishes whether the researcher's other findings reach production builds.

## The seven CVE records

N-able, acting as CVE Numbering Authority, published seven records on 10 November 2026 between 21:19 and 21:26 UTC (**Confirmed** [4] to [10]). Six were reserved the same day; CVE-2026-91000 was reserved on 14 September 2026 (**Confirmed** [10]).

| CVE | Vendor title | CWE (record) | CAPEC (record) | CVSS v4.0 | Privileges / interaction | CISA SSVC (11 Nov) | Source |
|---|---|---|---|---|---|---|---|
| CVE-2026-125883 | Multiple XXE Vulnerabilities | CWE-611 | CAPEC-146 | 9.3 Critical | None / none | Exploitation poc, Automatable yes, Technical Impact total | [4] |
| CVE-2026-125881 | Schema-hint SSRF via service import schema validation | CWE-918 | CAPEC-664 | 9.3 Critical | None / none | No entry when read | [5] |
| CVE-2026-125878 | Multiple OGNL Injection vulnerabilities | CWE-79 (see below) | CAPEC-240 | 8.7 High | Low / none | No entry when read | [6] |
| CVE-2026-125879 | Local privilege escalation to root via nable-writable syslog-ng config | CWE-266 | CAPEC-233 | 8.6 High | High / none | Exploitation none, Automatable no, Technical Impact total | [7] |
| CVE-2026-125882 | RCE via file repository upload path traversal | CWE-23 | CAPEC-126 | 8.6 High | High / none | No entry when read | [8] |
| CVE-2026-91000 | Insecure IPC Channels lead to local privilege escalation | CWE-306 | CAPEC-233 | 8.4 High (local vector) | Low / none | Exploitation none, Automatable no, Technical Impact total | [10] |
| CVE-2026-125880 | Stored XSS via MMS3 patch metadata (admin context) | CWE-644 | CAPEC-63 | 8.3 High | High / active | No entry when read | [9] |

Three points about the records themselves:

- **A title and a weakness that disagree.** CVE-2026-125878 is titled as OGNL injection, but its CWE field and description say CWE-79, cross-site scripting; NVD carries the same CWE-79 from the CNA, and the record does not list CWE-917, the CWE for expression language injection (**Confirmed** [6] [11]). This study cites the title and the recorded CWE side by side rather than choosing one.
- **A version string that disagrees with the build.** Six records say "before 26.4.1"; CVE-2026-91000 says "before 2026.4.1"; the fixed build is 2026.4.1.26 (**Confirmed** [4] [10] [2]). A scanner matching on the short form needs care (**Inferred**). CSO relays advice that patched servers may not show a new version number (**Reported** [32]).
- **NVD has not analyzed them.** NVD lists CVE-2026-125883 and CVE-2026-125878 as "Received", with only the CNA's CVSS v4.0 score (**Confirmed** [11]).

Each record links an N-able security advisory on the customer portal; those pages could not be opened without a browser, so their text is not checked (**Confirmed** that the link is present [4]).

## What the vendor says it fixed and what remains

N-able's blog of 11 November says all identified vulnerabilities that an unauthenticated user could exploit have been addressed; the remaining ones need an authenticated account, often with elevated privileges, or other limiting conditions, and will be fixed in later hotfixes phased by severity and exploitability (**Confirmed** as the vendor's statement [3]). It reports no indications of compromise within N-central hosted servers and says compromise of an individual customer environment needs an assessment of that environment (**Confirmed** [3]).

None of the status page, the HF2 release notes or the blog mentions the researcher's count of 33 or maps the seven CVEs to the findings (**Confirmed**, absence checked in all three [1] [2] [3]). Tenable says the same (**Reported** [16]); BleepingComputer says the hotfix covers "some" of the zero-days, including those N-able

considers most critical (**Reported** [26]); CSO says N-able has not confirmed how many of the 33 it could reproduce (**Reported** [32]).

## Part 3: The timeline

| Date (UTC unless stated) | Event | Grade | Source |
|---|---|---|---|
| 2025-08-13 | N-central 2025.3.1 GA fixes CVE-2025-8875 (insecure deserialization) and CVE-2025-8876 (command injection), both needing authentication; CISA adds both to KEV the same day | Confirmed | [34] [12] [13] |
| 2026-07-31 | N-able's Adlumin MDR detects a threat actor exploiting a previously unknown N-central vulnerability in a customer environment | Confirmed (vendor account) | [36] [37] |
| 2026-08-02 | N-central 2026.3 Hotfix 1 (2026.3.1.7) ships as mitigation for CVE-2026-18577, with host and network indicators for partners; CVE-2026-18577 published | Confirmed | [35] [13] |
| 2026-08-03 | CISA adds CVE-2026-18577 (incomplete patch for CVE-2026-18556, administrative account takeover) to KEV | Confirmed | [12] [13] |
| 2026-08-04 | CISA adds CVE-2026-18556 (authentication bypass) to KEV | Confirmed | [12] |
| 2026-08-06 | Hotfix 2 (2026.3.1.10) ships after a related attack path is found | Confirmed | [37] [36] |
| 2026-09-05 to 06 | 2026.3 Hotfix 4 (2026.3.1.14) fixes CVE-2026-86218, a pre-authentication RCE reported through N-able's disclosure program | Confirmed | [38] |
| 2026-09-08 | CISA adds CVE-2026-86218 to KEV, due 11 September | Confirmed | [12] |
| 2026-09-09 | N-able's blog says it has since seen a handful of successful exploits against customers | Confirmed (vendor account) | [39] |
| 2026-09-14 | CVE-2026-91000 (insecure IPC, local privilege escalation) reserved | Confirmed | [10] |
| 2026-10-02 | N-central 2026.4 release notes (build 2026.4.0.27) last updated; 2026.4 carries the fixes for CVE-2026-86206, CVE-2026-86207 and CVE-2026-86218 | Confirmed | [40] |
| 2026-11-09 04:14:21 (late 8 Nov, US time) | Researcher's commit "N-Able 0-Days" publishes 33 findings with proof-of-concept scripts | Confirmed (commit); Reported (substance) | [14] [15] |
| 2026-11-09 14:00 (dashboard) | N-able status incident 202584 starts: hosted and on-premises N-central, three regions, "Major Outage" | Confirmed | [1] |
| 2026-11-09 15:15 | Declared incident time per GovInfoSecurity; N-able's statement of no active exploitation as of this time, as Huntress quotes it | Reported | [28] [17] |
| 2026-11-09 17:35 | Previdian adds the finding set to its own watchlist | Confirmed (Previdian's record) | [19] |
| 2026-11-09 21:49:52 | Second commit adds the non-affiliation disclaimer | Confirmed | [14] [15] |
| 2026-11-09 about 22:08 | Previdian's N-central decoy starts recording 68 events from one source address | Demonstrated | [19] |

| Date (UTC unless stated) | Event | Grade | Source |
|---|---|---|---|
| 2026-11-09 to 10 (overnight) | watchTowr reports exploitation attempts against its N-central honeypots | Reported | [18] [30] |
| 2026-11-10 | HF2 (2026.4.1.26) release notes posted; seven CVE records published 21:19 to 21:26 | Confirmed | [2] [4] to [10] |
| 2026-11-10 | KEV catalog 2026.11.10 released 19:03Z, listing none of the seven | Confirmed | [12] |
| 2026-11-10 | H-ISAC TLP:WHITE bulletin: N-able had detected no active exploitation and no unauthorized data access | Confirmed | [22] [23] |
| 2026-11-10 17:30 ET | Huntress update: no Able2Shell exploitation in partner environments | Confirmed | [17] |
| 2026-11-11 01:04 (dashboard) | Status update: all hosted N-central servers in all regions upgraded | Confirmed | [1] |
| 2026-11-11 | CISA ADP SSVC entries added to CVE-2026-125883, CVE-2026-125879 and CVE-2026-91000 | Confirmed | [4] [7] [10] |
| 2026-11-11 | N-able blog: unauthenticated paths fixed, more hotfixes to come, disclosure claims "inaccurate"; Previdian maps the XXE finding to CVE-2026-125883 | Confirmed | [3] [19] |
| 2026-11-11 | Shadowserver count of exposed servers down to just over 148 from 1,338 on 9 November (BleepingComputer) | Reported | [26] |

GovInfoSecurity counts HF2 as N-able's fifth emergency hotfix since 1 August 2026, and the Cloud Security Alliance's daily briefing calls Able2Shell N-central's fourth security event of 2026 (**Reported** [28] [24]).

## Part 4: Exploitation and defender telemetry

The record after the drop is best read as a ladder, from what the vendor saw to what reached a catalog.

| Rung | Observer | What it saw | Grade | Source |
|---|---|---|---|---|
| Vendor | N-able | Scanning activity associated with the published code; no indications of compromise in hosted servers | Confirmed | [1] [3] |
| Deception | watchTowr | Exploitation attempts against its honeypots overnight after the release; probing within 12 hours and later attempts matching the published scripts | Reported (watchTowr's own page not found) | [18] [30] [33] |
| Deception | Previdian | 68 events from one source address from about 22:08 UTC on 9 November: probing, XXE and external-entity attempts, attempts to read sensitive local files including directory traversal, and probing of the service-import and log-submission methods | Demonstrated | [19] |
| Deception | Defused | Probing of the attack surface within 24 hours | Reported (Defused's own statement not found) | [26] [30] |
| MDR | Huntress | No evidence of Able2Shell exploitation in partner environments; contacting potentially vulnerable customers | Confirmed | [17] |

| Rung | Observer | What it saw | Grade | Source |
|---|---|---|---|---|
| MDR | Field Effect | No exploitation reported in its customer environments; attributes post-release scanning to researchers; presents no telemetry of its own | Confirmed | [20] |
| Sector | H-ISAC | Relays N-able: no active exploitation, no unauthorized data access; no honeypot or scanning statement | Confirmed | [23] |
| Catalog | CISA | None of the seven in KEV; SSVC "poc" for CVE-2026-125883 only, "none" for two local flaws | Confirmed | [12] [4] [7] [10] |

Previdian is explicit about the limits of its own data: the decoy showed no account takeover, no JSP execution, no operating-system command execution and no full replay of the public XXE-to-RCE chain, and the activity is not evidence that any hosted, customer or downstream system was compromised (**Demonstrated** [19]). Beazley states that no confirmed compromise of a customer server through Able2Shell had been reported (**Reported** [18]), and Tenable says no threat actor had been linked to Able2Shell as of 10 November (**Confirmed** as Tenable's statement [16]).

Previdian also shows how private catalogs move ahead of public ones: it put the finding set on its watchlist on 9 November and on its own "Previdian KEV" list (not CISA's) on 10 November, then mapped the XXE finding to CVE-2026-125883 once the CVE existed on 11 November (**Confirmed** as Previdian's record [19]).

Two attribution claims about the earlier N-central exploitation circulate in the secondary record and disagree with each other. GovInfoSecurity says researchers in August linked a ransomware strain to the China-linked Storm-1175, possibly targeting an N-able RMM flaw; Beazley says researchers in October 2026 linked Volt Typhoon (see the China threat actors study) to zero-day exploitation of two earlier N-central flaws (**Reported** [28] [18]). Neither ties any actor to Able2Shell, neither was traced to a primary, and this study binds no group on either basis.

The reading of the ladder: by 11 November the published code was being tried against internet-facing N-central decoys and honeypots, N-able saw scanning tied to it, and nothing in the opened record shows it landing on a real customer (**Inferred** from [1] [3] [17] [18] [19] [23]). The Cloud Security Alliance briefing advises treating exposed servers as possibly compromised anyway (**Reported** [24]), which is the prudent stance for any server that was reachable between the drop and the upgrade (**Inferred**).

## Part 5: The RMM attack surface

Able2Shell lands on a pattern the public record has documented for five years. The six landmarks below are the ones the opened primaries support.

| Date | Landmark | What it shows about RMM as a single point of compromise | Grade | Source |
|---|---|---|---|---|
| 2021-07-02 | Kaseya VSA and REvil | One on-premises RMM server per MSP; ransomware pushed to managed endpoints; fewer than 60 direct customers and fewer than 1,500 downstream businesses | Confirmed | [44] [45] [47] [48] |

| Date | Landmark | What it shows about RMM as a single point of compromise | Grade | Source |
|---|---|---|---|---|
| 2024-02-19 to 22 | ConnectWise ScreenConnect CVE-2024-1709 | Authentication bypass to an administrator account on the management interface; in KEV three days after the bulletin, known ransomware use | Confirmed | [49] [50] [12] |
| 2025-01 to 2025-06 | SimpleHelp CVE-2024-57727 | Unpatched RMM at a software vendor used against its downstream customers in ransomware attacks | Confirmed (CISA, KEV); Reported (Sophos) | [51] [52] [53] [54] [12] |
| 2025-08-13 | N-central CVE-2025-8875 and CVE-2025-8876 | Both needed authentication; KEV the day the fix shipped | Confirmed | [34] [12] |
| 2026-07-31 to 09-08 | N-central CVE-2026-18577, CVE-2026-18556, CVE-2026-86218 | All three in KEV; the July intrusion used a previously unknown flaw, and the attacker used N-central's Take Control feature to reach managed endpoints | Confirmed | [36] [37] [35] [38] [12] |
| 2026-11-09 to 11 | Able2Shell | 33 alleged findings published without notice; hosted N-central offline worldwide; seven CVEs fixed in HF2 | Confirmed (vendor); Reported (researcher, press) | [1] [2] [14] |

## Kaseya VSA, July 2021

Kaseya learned of a potential VSA incident around midday US Eastern on Friday 2 July 2021, shut down its SaaS servers as a precaution and told on-premises customers to shut their VSA servers down (**Confirmed** [44]). By 5 July it put direct compromise at fewer than 60 Kaseya customers, all on VSA On-Premises, and downstream impact at fewer than 1,500 businesses, up from an estimate of fewer than 40 on 2 July (**Confirmed** [44]). The on-premises patch shipped on 11 July at 4:00 PM EDT and all SaaS customers were live by 3:30 AM EDT on 12 July; Kaseya said VSA was the only product affected (**Confirmed** [44]). CISA and the FBI described the event as ransomware used against MSPs and their downstream customers through a vulnerability in VSA on-premises products (**Confirmed** [45]). The Dutch Institute for Vulnerability Disclosure (DIVD) had reported seven VSA vulnerabilities to Kaseya on 6 April 2021, some patched in April and May, and says one of the two vulnerabilities used in the attack was one it had disclosed (**Confirmed** [47]). NVD records CVE-2021-30116 as credential disclosure in VSA before 9.5.7, exploited in the wild in July 2021 (CWE-522) (**Confirmed** [48]). KEV lists three Kaseya VSA CVEs, all with known ransomware use: CVE-2021-30116 (added 3 November 2021), CVE-2018-20753 (added 13 April 2022, which KEV says lets unprivileged remote attackers run PowerShell payloads on all managed devices) and CVE-2017-18362 (added 24 May 2022) (**Confirmed** [12]). The library's home study for Kaseya is Chronicle 2021, which maps the event to T1190, T1199 and T1072 and links S0496 REvil and G0115 GOLD SOUTHFIELD, noting that neither live ATT&CK entry mentions Kaseya (**Confirmed** [59]). The ransomware ecosystem study places the Kaseya VSA attack and REvil in the wider ransomware record.

The parallel with November 2026 is direct: in both cases the vendor's first move was to take its hosted service offline and tell on-premises operators to shut their servers down (**Confirmed** [44] [1]).

## ConnectWise ScreenConnect, February 2024

ConnectWise published its ScreenConnect 23.9.8 bulletin on 19 February 2024 for issues reported on 13 February: CVE-2024-1709 (CVSS 10.0, authentication bypass) and CVE-2024-1708 (8.4, path traversal) in 23.9.7 and earlier (**Confirmed** [49]). The first version said there was no evidence of exploitation; the 20 February update reported investigated suspicious activity; cloud instances were already remediated (**Confirmed** [49]). NVD records CVE-2024-1709 as an authentication bypass using an alternate path or channel, published 21 February 2024 (**Confirmed** [50]). CISA added it to KEV on 22 February 2024 with known ransomware use and describes it as letting an attacker with network access to the management interface create a new administrator-level account (**Confirmed** [12]). CVE-2024-1708 followed into KEV on 28 April 2026, and ScreenConnect kept returning: CVE-2025-3935 (added 2 June 2025) and CVE-2026-84869 (added 11 September 2026; per KEV, file transfer and execution through an active remote session without authorization or host confirmation) (**Confirmed** [12]). ATT&CK carries ScreenConnect as the software object S0591 ConnectWise (alias ScreenConnect) (**Confirmed** [58]). The healthcare threat watchlist covers its exploitation by Black Basta and Medusa, and the ransomware ecosystem study records Black Basta affiliates exploiting it from February 2024.

## SimpleHelp, 2025

SimpleHelp's January 2025 knowledge-base article covers CVE-2024-57726, CVE-2024-57727 and CVE-2024-57728 in SimpleHelp 5.5.7 and earlier, fixed in 5.5.8 or in patched 5.4.10 and 5.3.9, and says an attack would likely compromise the server first and then use it against registered endpoints (**Confirmed** [51]). NVD records CVE-2024-57727 as an unauthenticated path traversal that lets attackers download server configuration files containing secrets and hashed passwords (CWE-22), published 15 January 2025 (**Confirmed** [52]). KEV added it on 13 February 2025 with known ransomware use; CVE-2024-57726 and CVE-2024-57728 followed on 24 April 2026, and CVE-2026-48558 (an OIDC authentication bypass) on 29 June 2026 (**Confirmed** [12]). CISA advisory AA25-163A (12 June 2025) says ransomware actors used unpatched SimpleHelp to compromise a utility billing software provider and its downstream customers in double-extortion attacks, with activity since January 2025, and tells vendors to notify downstream customers and customers to check whether SimpleHelp is embedded in third-party software (**Confirmed** [53]). Sophos MDR reports that an actor reached an MSP's SimpleHelp instance, used it to gather information on several customer estates, deployed DragonForce ransomware and stole data; Sophos has medium confidence the chain used the three SimpleHelp CVEs (**Reported** [54]). ATT&CK has no group object for DragonForce (**Confirmed** [58]). The ransomware ecosystem study covers DragonForce and lists CVE-2024-57727 among the CVEs ransomware operators used.

## N-central before Able2Shell

N-able's 13 August 2025 status post announced N-central 2025.3.1 with the fix for CVE-2025-8875 and CVE-2025-8876, said both require authentication, and said nothing about exploitation; CISA added both to KEV the same day (**Confirmed** [34] [12]). NVD lists CWE-502 for CVE-2025-8875, and CWE-20 from the CNA with CWE-78 added by NVD for CVE-2025-8876, both CVSS v4.0 9.4 from the CNA (**Confirmed** [61] [62]).

In summer 2026 the pattern became an intrusion. N-able says its Adlumin MDR detected a threat actor on 31 July 2026 exploiting a previously unknown N-central vulnerability in a customer environment; the actor used the Take Control feature to reach managed devices and registered Cloudflare tunnel services for persistence; a limited number of customers were affected; Hotfix 1 (2 August) and Hotfix 2 (6 August) were applied to hosted environments; and customers who patched more than a few days late should treat their environment as

potentially compromised (**Confirmed**, vendor account [36] [37]). The Hotfix 1 post gave partners indicators to check, including an unexpected executable in users' Documents folders, a registered Cloudflared service and inbound connections from listed addresses (**Confirmed** [35]). The Hacker News reports that the attackers gained N-central administrator access through CVE-2026-18577, used Take Control to connect to managed systems, and kept access through the tunnel after their N-central access was revoked (**Reported** [42]). KEV says CVE-2026-18577 is the result of an incomplete patch for CVE-2026-18556; both are authentication bypasses (CWE-288) (**Confirmed** [12]).

September brought the third 2026 entry. N-central 2026.3 Hotfix 4 (build 2026.3.1.14, posted 6 September) fixed CVE-2026-86218, a critical pre-authentication RCE (CWE-96, CVSS v4.0 10.0) reported through N-able's disclosure program; the status post said N-able had no confirmation of exploitation in production (**Confirmed** [38]). N-able's own blog, updated the same day, said the flaw had been exploited in the wild, and by 9 September reported a handful of successful customer exploits (**Confirmed** [39]). Help Net Security reported the same split between the public advisory and an urgent customer notice calling it a zero-day seen in the wild (**Reported** [43]). Canada's Cyber Centre recorded N-able's statement that CVE-2026-86218 was exploited and open-source reporting that CVE-2026-86207 was exploited too (**Confirmed** [41]). CISA added CVE-2026-86218 to KEV on 8 September with a three-day due date (**Confirmed** [12]). All five N-central KEV entries show ransomware use "Unknown" (**Confirmed** [12]).

Tenable says it is not known whether Able2Shell relates to any of the five earlier KEV CVEs (**Reported** [16]).

### What the landmarks share

Two joint advisories set the frame. In AA22-131A (May 2022) the Five Eyes agencies warn that an MSP's trusted connectivity and privileged access make a vulnerable MSP an initial access vector into many customer networks, with cascading effects (**Confirmed** [55]). In AA23-025A (January 2023) CISA, NSA and MS-ISAC warn that legitimate RMM software is used as a backdoor for persistence and command and control, generally does not trigger antivirus, and that MSPs are frequent targets because of their trust relationships with many customers (**Confirmed** [56]).

Across the six landmarks, the RMM server is one point of compromise for every managed customer. Kaseya VSA and SimpleHelp were used to deliver ransomware downstream; the 2026 N-central attacker drove the product's own remote-control feature into managed endpoints; and each vendor's first move was to take its hosted service offline or patch it centrally while self-hosted operators lagged (**Inferred** from [44] [53] [37] [49] [1]). Shadowserver still counted just over 148 internet-exposed N-central servers on 11 November, down from 1,338 on 9 November; the count does not say how many are self-hosted or still unpatched (**Reported** [26]).

## Part 6: The disclosure dispute

The record supports four statements, and they do not resolve into one story.

- **The researcher gave no notice.** He told BleepingComputer he released the findings without notifying N-able beforehand (**Reported** [25]).
- **The researcher's stated reason is an earlier report.** He says two unrelated RCEs and a privilege-escalation flaw in a different N-able product, reported about five to six months earlier, remained unpatched; follow-ups over four to six weeks went unanswered; no bounty was paid. N-able did not respond to these allegations in that report (**Reported** [26] [25]).

- **The vendor disputes the framing.** N-able's 9 November alert spoke of "non-responsible communication" (**Reported** [28]). Its 11 November blog calls claims that it ignored responsible disclosure inaccurate, says the 9 November findings did not come through its established reporting channels, and points to its bug bounty program (**Confirmed** as the vendor's statement [3]). Cybersecurity Dive reports N-able's chief executive saying the disclosure came without coordination and before the findings were verified (**Reported** [33]).
- **Some of the fixed work predates the drop.** CVE-2026-91000 was reserved in September (**Confirmed** [10]). CVE-2026-125882 is credited to another researcher, though its record does not say when that report arrived (**Confirmed** [8]). Tenable notes that N-able does not say whether it had advance notice (**Reported** [16]); GovInfoSecurity could not reach the researcher on whether coordination had been discussed and notes that coordinated disclosure commonly runs on a 90-day window (**Reported** [28]).

On the opened record this was an unpatched full disclosure, with proof-of-concept code for every finding, tested on a pre-release build, with no advance notice by the researcher's own statement (**Inferred** from [14] [25] [28]). The defender's cost of that choice is visible in the timeline: under two days between publication and a fixed build, with proof-of-concept code in public the whole time and the hosted service dark (**Inferred** from [14] [1] [2]). The researcher's complaint, that earlier reports went unpatched and follow-ups unanswered, is part of the record. N-able's 11 November blog rejects the claim that it ignored responsible disclosure but does not address those earlier reports point by point (**Reported** [26]; **Confirmed** as the vendor's statement [3]). This study does not judge the dispute; it records that a defender planning for RMM risk has to plan for both failure modes, slow vendor fixes and zero-notice publication.

## Part 7: The vulnerability-management view

- **The scores and the urgency diverge.** The CVSS v4.0 scores run from 8.3 to 9.3, and only two of the seven need no privileges [4] to [10]. Taken alone, that reads as "patch in the next cycle". The vendor's own behavior (a hosted fleet taken offline in three regions, on-premises told to disconnect) and published proof-of-concept code for every finding (the researcher's claim) say "emergency change now" (**Inferred** from [1] [14]). When the vendor pulls its own service, that is the priority signal, whatever the score.
- **SSVC moved before KEV, and KEV may never move.** CISA's SSVC entry on CVE-2026-125883 records a public proof of concept, automatable, with total technical impact, on 11 November [4]; KEV lists none of the seven as of catalog 2026.11.10 [12]. KEV requires reliable evidence of exploitation, and CISA counts attempted exploitation, including code run against a honeypot, as active exploitation (**Confirmed** [60]). As of catalog 2026.11.10 none of the seven is listed [12]. A program that waits for KEV on an RMM server that was reachable during the drop is waiting for a signal it should already be hunting for (**Inferred**). Compare the Linux TCP use-after-free study, another case where severity and catalog status diverged.
- **Commercial ratings are early but partial.** Tenable rates CVE-2026-125883 a Vulnerability of Interest and CVE-2026-125878, CVE-2026-125881 and CVE-2026-125882 Vulnerabilities Being Monitored in its Vulnerability Watch (**Confirmed** as Tenable's rating [16]). Three of the seven carry no rating there; the two local privilege escalations matter most to an attacker who already has local access to the server (CVE-2026-125879 names a nable-writable syslog-ng config; CVE-2026-91000 has a local attack vector) (**Inferred** from [7] [10]).
- **The findings do not map to the CVEs.** A scanner or ticket keyed on CVE ids sees seven issues; the researcher's index has 33; N-able says the unauthenticated ones are fixed and the authenticated ones will

follow [3] [14]. Track the product's latest hotfix, not a CVE list, until N-able publishes a mapping (**Inferred**).

- **The fix is a fleet change, not a server patch.** HF2 needs every Agent and Probe upgraded in order [2]; upgrading Probes before Agents breaks Agent-Probe communication (**Confirmed** [2]). Plan the change window for the whole managed estate (**Inferred**).
- **The product's history is a priority input.** Five KEV entries between August 2025 and September 2026, one an incomplete fix for another, and one that N-able says was used successfully against a handful of customers [12] [39]. A product with that history earns a shorter patch SLA and a standing hunt (**Inferred**). See the Vulnerability Prioritization Reference and Triage a CVE.

### Overstated and understated

- **Overstated: "33 zero-days."** It is the researcher's count. The vendor has published seven CVEs, has not mapped them to the findings, and one of the seven is credited to someone else (**Confirmed** [2] [3] [8]; the count **Reported** [16]). The seven scored records run from 8.3 High to 9.3 Critical (**Confirmed** [4] to [10]); no opened source scores the other findings (**Inferred**).
- **Overstated: "customers compromised."** Attempts against honeypots and decoys are not a customer compromise, although CISA's KEV criteria count them as attempted exploitation (**Confirmed** [60]); as of 11 November no source confirms a customer compromise through Able2Shell (**Confirmed** [3] [17] [19] [23] for what each says; **Reported** [18]; **Inferred** for the absence).
- **Overstated: "pre-release build" as a reason for comfort.** The seven CVE records say N-central before 26.4.1 is affected (**Confirmed** [4] to [10]).
- **Understated: the vendor's own response.** A worldwide hosted shutdown within hours, legacy MDM removed and built-in remote control switched off (**Confirmed** [1] [2]) are product changes that no CVE list shows (**Inferred**).
- **Understated: the absence of a KEV entry.** It reflects the evidence CISA had acted on by catalog 2026.11.10, not safety (**Confirmed** [12] [60] [4] for the catalog and its criteria; **Inferred** for the reading).
- **Understated: the blast radius.** One N-central server reaches every managed client, which is why the defender guidance says to assess every client network the server manages, not just the server (**Reported** [32]; **Confirmed** [20] as its own advice), and why the product's five KEV entries matter more than the score of any one CVE (**Confirmed** [12] for the entries; **Inferred** for the weighting).

## Part 8: The defender view

### Contain and upgrade

1. Keep self-hosted servers disconnected until they run 2026.4 HF2 (2026.4.1.26) or later (**Confirmed** guidance [1] [23]). Upgrade from a supported path (2025.4 onward); older servers move to a supported build first [2].
2. Upgrade Agents first, then Probes, across every customer, hosted or not [2].
3. Expect built-in remote control to be off until a later fix; Take Control remains available [2]. Treat its return as a change to re-review (**Inferred**).
4. Watch for the follow-up hotfix that N-able has announced [1] [3].

### Reduce exposure

- Do not expose N-central to the internet or untrusted networks (runZero, before the CVEs existed) [21]; restrict management interfaces to an internal VLAN or VPN (H-ISAC) or to administrative networks (Field Effect) [23] [20].
- Apply CISA's RMM guidance: audit remote access tools, allowlist the approved RMM, allow it only from inside the network over approved remote access (VPN or VDI), block common RMM ports at the boundary, and review logs for RMM execution (**Confirmed** [56]).

### Hunt

- Review login and authentication activity from 8 November 2026 onward for unauthorized new administrator accounts, newly deployed scripts and anomalous remote-access sessions (Huntress) (**Confirmed** [17]; also relayed by Tenable [16]). Huntress notes that earlier N-central exploitation led to unauthorized scripts and tools being pushed to managed systems (**Confirmed** [17]).
- Review audit trails and scheduled jobs for new administrators, unexpected PowerShell or bash runs and automation policy changes, and watch managed endpoints for unusual child processes, remote-control sessions and silent installs by the agent (H-ISAC) (**Confirmed** [23]).
- Review privilege and configuration changes, software deployments, script execution and remote-control sessions originating from N-central (Field Effect) (**Confirmed** as Field Effect's advice [20]).
- From the summer 2026 intrusion, check managed Windows endpoints for an unexpected Cloudflared service and unexpected executables in users' Documents folders, the indicator types N-able published for CVE-2026-18577 (**Confirmed** [35]). These are indicators of the earlier campaign, not of Able2Shell (**Inferred**).

### Recover

- Preserve logs and snapshots before changing anything, then rotate administrator and technician credentials, asset-discovery database credentials, agent registration tokens and ecosystem agent keys (ThreatDefence, via CSO) (**Reported** [32]). Those are the same credential types the README lists as disclosure findings [14] (**Inferred** link).
- Inventory everything N-central can reach (domain controllers, hypervisors, backups, identity providers and security tools) and rotate platform-linked credentials and API keys (**Confirmed** H-ISAC [23]; Field Effect [20]).
- Assess every client network the server manages, not just the server (defender guidance relayed by CSO) (**Reported** [32]). N-able's own statement that no hosted server showed signs of compromise does not cover individual customer environments, and N-able says so [3].

### For the customers of an MSP

CISA's Kaseya-era guidance still reads as current: MFA on every account the organization controls, starting with privileged, administrative and remote-access users; least privilege and logical separation of customer environments at the MSP; MSP accounts kept out of administrator groups and restricted to the systems they manage; a dedicated VPN for MSP access; MSP logs correlated for account misuse; and air-gapped backups (**Confirmed** [46] [45]). AA25-163A adds a question every organization can ask its software suppliers: is an RMM embedded in the product you sold us (**Confirmed** [53])?

## Part 9: MITRE mappings

No ATT&CK group, software or campaign object covers Able2Shell or N-central, and no opened source attributes the activity to anyone (**Confirmed** [58] [16]). Neither the H-ISAC bulletin nor AA25-163A cites ATT&CK ids [23] [53], so every binding below is this study's mapping from the dated record. Each id was checked against the library's ATT&CK v20.0 data (`data/attack/technique_profiles.jsonl`), with the tactic as recorded there, and against the live ATT&CK site, which shows v20.1 [57] [58]. Note that T1219 is now named Remote Access Tools, not Remote Access Software [57]. ATT&CK for ICS does not apply: N-central manages IT endpoints.

### ATT&CK Enterprise techniques: the Able2Shell record

| ATT&CK id | Name | Tactic (v20) | Dated event or report | Basis | Source |
|---|---|---|---|---|---|
| T1595.002 | Vulnerability Scanning | Reconnaissance | N-able observes scanning tied to the published code (status page, 2026-11-10); Previdian decoy probing from 2026-11-09 | Observation Confirmed (vendor) and Demonstrated (decoy); mapping Inferred | [1] [3] [19] |
| T1190 | Exploit Public-Facing Application | Initial Access | CVE-2026-125883 and CVE-2026-125881, network vector with no privileges (2026-11-10); exploitation attempts against honeypots (2026-11-09 to 10) | Vulnerability class Confirmed; attempts Reported; no confirmed compromise; mapping Inferred | [4] [5] [18] [19] |
| T1068 | Exploitation for Privilege Escalation | Privilege Escalation | CVE-2026-125879 and CVE-2026-91000, local privilege escalation (2026-11-10); README chains 3 and 4 reach root | Vulnerability class Confirmed; mapping Inferred | [7] [10] [14] |
| T1059 | Command and Scripting Interpreter | Execution | README claims code execution as `nable` and as root (2026-11-09); the record does not say which interpreter, so no sub-technique | Reported (researcher claim) | [14] [16] |
| T1136 | Create Account | Persistence | README claims chain 1 can create an enabled administrator account (2026-11-09); Huntress hunts for unauthorized new administrator accounts (2026-11-10) | Reported (researcher claim); hunt guidance Confirmed | [14] [17] |

## ATT&CK Enterprise techniques: the RMM landmarks

| ATT&CK id | Name | Tactic (v20) | Dated event or report | Basis | Source |
|---|---|---|---|---|---|
| T1190 | Exploit Public-Facing Application | Initial Access | Kaseya VSA (2021-07-02); ScreenConnect CVE-2024-1709 (KEV 2024-02-22); SimpleHelp CVE-2024-57727 (KEV 2025-02-13); N-central CVE-2026-86218 pre-auth RCE (KEV 2026-09-08) | Exploitation Confirmed (KEV, CISA, vendor); mapping Inferred | [45] [12] [53] [38] [59] |
| T1219 | Remote Access Tools | Command and Control | N-central intrusion: actor used Take Control to reach managed devices (2026-07-31 onward); HF2 disables built-in remote control (2026-11-10) | Use Confirmed (vendor account); mapping Inferred | [36] [37] [2] |
| T1572 | Protocol Tunneling | Command and Control | N-central intrusion: Cloudflare tunnel services registered for persistence (2026-08-02 to 10) | Use Confirmed (vendor account); mapping Inferred | [35] [37] [42] |
| T1543.003 | Windows Service | Persistence, Privilege Escalation | N-central intrusion: a registered Cloudflared service among the indicators (2026-08-02) | Indicator Confirmed; Windows service platform Inferred | [35] |
| T1078 | Valid Accounts | Stealth, Persistence, Privilege Escalation, Initial Access | N-central intrusion: attackers held N-central administrator access after CVE-2026-18577 (reported 2026-08-08) | Reported; mapping Inferred | [42] [12] |
| T1136 | Create Account | Persistence | ScreenConnect CVE-2024-1709 lets an attacker create a new administrator-level account (KEV 2024-02-22) | Capability Confirmed (KEV); mapping Inferred | [12] [50] |
| T1072 | Software Deployment Tools | Execution, Lateral Movement | Kaseya VSA used to push ransomware to managed endpoints (2021-07-02); mapped in the library's home study | Confirmed in the home study | [59] [45] |
| T1199 | Trusted Relationship | Initial Access | Kaseya MSP customers (2021); SimpleHelp at a software provider used against its downstream customers (AA25-163A, 2025-06-12); AA22-131A (2022-05-11) | Advisories Confirmed; mapping Inferred (also Inferred in the home study) | [45] [53] [55] [59] |
| T1486 | Data Encrypted for Impact | Impact | REvil ransomware through Kaseya VSA (2021-07-02); ransomware through SimpleHelp (AA25-163A, 2025-06-12); DragonForce through an MSP's SimpleHelp (Sophos, 2025) | Confirmed (CISA); Sophos Reported | [45] [53] [54] |
| T1552.001 | Credentials In Files | Credential Access | SimpleHelp CVE-2024-57727 exposes server configuration files containing secrets and hashed passwords (NVD, 2025-01-15) | Capability Confirmed (NVD); mapping Inferred | [52] |

The parent T1595 is context only. Sub-technique T1136.001 (Local Account) is not used: the accounts in these records are application administrator accounts, not operating-system accounts (**Inferred**).

## Group, software and campaign objects

| Object | Id | Relation to this study | Source |
|---|---|---|---|
| Groups | none for Able2Shell | No source links an actor; Storm-1175 and Volt Typhoon claims about earlier N-central flaws are Reported, conflicting and not traced to a primary, so not bound | [16] [18] [28] |
| Group (context) | G0115 GOLD SOUTHFIELD | REvil's operator, linked from the Kaseya home study | [59] [58] |
| Software (context) | S0496 REvil | The ransomware in the Kaseya VSA attack | [59] [58] |
| Software (context) | S0591 ConnectWise | ATT&CK's object for the ScreenConnect product (alias ScreenConnect); named here only as the product of the 2024 landmark | [58] |
| Software | none for DragonForce | ATT&CK has no DragonForce object | [58] |
| Campaigns | none | No ATT&CK campaign covers N-central, Kaseya, ScreenConnect, SimpleHelp or RMM | [58] |

## CWE and CAPEC

| Id | Name (library data) | Where it appears | Basis | Source |
|---|---|---|---|---|
| CWE-611 | Improper Restriction of XML External Entity Reference | CVE-2026-125883 | Confirmed | [4] [58] |
| CWE-918 | Server-Side Request Forgery | CVE-2026-125881 | Confirmed | [5] [58] |
| CWE-79 | Improper Neutralization of Input During Web Page Generation | CVE-2026-125878 (record title says OGNL injection) | Confirmed as recorded; the mismatch is flagged in Part 2 | [6] [11] [58] |
| CWE-266 | Incorrect Privilege Assignment | CVE-2026-125879 | Confirmed | [7] [58] |
| CWE-23 | Relative Path Traversal | CVE-2026-125882 | Confirmed | [8] [58] |
| CWE-306 | Missing Authentication for Critical Functionality | CVE-2026-91000 | Confirmed | [10] [58] |
| CWE-644 | Improper Neutralization of HTTP Headers for Scripting Syntax | CVE-2026-125880 | Confirmed | [9] [58] |
| CWE-502 | Deserialization of Untrusted Data | CVE-2025-8875 | Confirmed | [61] |
| CWE-20 | Improper Input Validation | CVE-2025-8876 (NVD adds CWE-78) | Confirmed | [62] |
| CWE-288 | Authentication Bypass Using an Alternate Path or Channel | CVE-2026-18556, CVE-2026-18577, ScreenConnect CVE-2024-1709 | Confirmed | [12] |
| CWE-96 | Improper Neutralization of Directives in Statically Saved Code | CVE-2026-86218 | Confirmed | [12] [38] |
| CWE-522 | Insufficiently Protected Credentials | Kaseya CVE-2021-30116 | Confirmed | [48] |
| CWE-22 | Improper Limitation of a Pathname to a Restricted Directory | SimpleHelp CVE-2024-57727 | Confirmed | [52] |
| CAPEC-146 | XML Schema Poisoning | CVE-2026-125883 record | Confirmed | [4] |
| CAPEC-221 | Data Serialization External Entities Blowup | Related to CWE-611 in the library's CWE data | Mapping Confirmed; fit Inferred | [58] |
| CAPEC-664 | Server Side Request Forgery | CVE-2026-125881 record | Confirmed | [5] |
| CAPEC-240 | Resource Injection | CVE-2026-125878 record | Confirmed | [6] |
| CAPEC-233 | Privilege Escalation | CVE-2026-125879 and CVE-2026-91000 records | Confirmed | [7] [10] |
| CAPEC-126 | Path Traversal | CVE-2026-125882 record | Confirmed | [8] |
| CAPEC-63 | Cross-Site Scripting (XSS) | CVE-2026-125880 record | Confirmed | [9] |

The library has no per-id CWE pages; see the CWE Reference.

## D3FEND countermeasures

The library's D3FEND data maps T1190 to Inbound Traffic Filtering, Network Traffic Filtering and Remote Terminal Session Detection; T1199 and T1219 to Remote Terminal Session Detection and Network Traffic Filtering; T1078 and T1136 to User Account Permissions and Access Modeling; T1059 to Executable Allowlisting and File Integrity Monitoring; and T1072 to File Integrity Monitoring, Software Update and Software Inventory (**Confirmed** [58]). Multi-factor Authentication, Local Account Monitoring, Credential Rotation and Administrative Network Activity Analysis have library pages but are fitted to this study by its own reading (**Inferred**).

| D3FEND id | Countermeasure | Fit to this study | Basis | Source |
|---|---|---|---|---|
| D3-SU | Software Update | HF2 on the server, then Agents, then Probes | Library maps it to T1072; fit Inferred | [2] [58] |
| D3-SWI | Software Inventory | Find every N-central server and any RMM embedded in third-party software | Library maps it to T1072; fit Inferred | [53] [58] |
| D3-ITF | Inbound Traffic Filtering | Management interface off the internet | Library maps it to T1190 | [21] [23] [58] |
| D3-NTF | Network Traffic Filtering | Admin VLAN or VPN only; block common RMM ports | Library maps it to T1190, T1199, T1219 | [23] [56] [58] |
| D3-RTSD | Remote Terminal Session Detection | Anomalous remote-control and Take Control sessions | Library maps it to T1190, T1199, T1219 | [17] [37] [58] |
| D3-UAP | User Account Permissions | MSP accounts out of customer administrator groups; least privilege | Library maps it to T1078, T1136 | [46] [58] |
| D3-AM | Access Modeling | Map what N-central and its accounts can reach | Library maps it to T1078, T1136 | [20] [23] [58] |
| D3-LAM | Local Account Monitoring | New administrator accounts since 8 November | Inferred | [17] [58] |
| D3-MFA | Multi-factor Authentication | Privileged, administrative and remote-access users first | Inferred | [46] [58] |
| D3-CRO | Credential Rotation | Administrator, technician, asset-discovery credentials, registration tokens, agent keys | Inferred | [32] [23] [58] |
| D3-ANAA | Administrative Network Activity Analysis | Automation policy changes, deployments and script runs from N-central | Inferred | [20] [23] [58] |
| D3-EAL | Executable Allowlisting | Allowlist the approved RMM; block others | Library maps it to T1059; fit Inferred | [56] [58] |
| D3-FIM | File Integrity Monitoring | Unexpected executables and services on managed endpoints | Library maps it to T1059, T1072; fit Inferred | [35] [58] |

## Navigator layer

navigator/library-layers/nable-ncentral-able2shell-2026.json carries the techniques in the two tables above (ATT&CK v20, domain `enterprise-attack`) and is listed on the Navigator layers page. Score 100 marks a technique bound to the Able2Shell record by a Confirmed primary (T1595.002, T1190, T1068); score 50 marks the researcher's claims (T1059, T1136) and the RMM-landmark context techniques (T1219, T1572, T1543.003, T1078, T1072, T1199, T1486, T1552.001). Each entry's comment names the source numbers.

MITRE ATT&CK, CWE, CAPEC and D3FEND content is used under the terms recorded in THIRD_PARTY_NOTICES.md.

## Cross-cutting themes

- **One server, every customer.** An RMM server is a deployment tool, a remote-access tool and a credential store for every managed client at once. Kaseya VSA, SimpleHelp and the 2026 N-central intrusion each turned that position against the customers behind it [45] [53] [37]. The same "one trusted product, many victims" pattern drives the SolarWinds and SUNBURST study, where the trusted channel was a software update rather than an agent (**Inferred**).
- **Hosted gets fixed first; self-hosted is the long tail.** ScreenConnect's cloud was remediated before the bulletin, Kaseya's SaaS came back within ten days, N-able upgraded every hosted server in under two days, and Shadowserver still counted just over 148 internet-exposed N-central servers on 11 November [49] [44] [1] [26] (**Inferred** from these). The risk concentrates on the operators least able to move quickly.
- **Vendors now switch features off.** HF2 removed legacy MDM and disabled built-in remote control [2]. Removing a feature is the fastest way to remove its attack surface, and defenders should expect it and plan for the lost function (**Inferred**).
- **Counts are claims until the vendor maps them.** "33 zero-days" and "seven CVEs" describe different things, and the mapping between them is missing (**Confirmed** [3] for the missing mapping; **Reported** [14] [16] for the count). The same caution applies to exposure counts: Shadowserver and Censys measured different things (**Reported** [26] [30]; **Inferred** for the reading).
- **Evidence thresholds are not safety thresholds.** Vendor scanning reports, honeypot attempts, MDR silence, an SSVC "poc" and an empty KEV entry all describe the same week [1] [18] [17] [4] [12]. Each is honest about what it measures; none says the reachable servers were safe (**Inferred**).
- **Disclosure is a two-sided failure mode.** A researcher who says earlier reports went unanswered published without notice; the vendor says the findings never came through its channels [26] [3]. Programs that depend on RMM need a plan for both: slow fixes and zero-notice exploits (**Inferred**).
- **AI-assisted discovery raises the volume.** The researcher says the discovery was AI-assisted [25]. Thirty-three findings in one product from one researcher fits the pattern the AI Threats 2026 study describes, where vulnerability discovery outpaces patch capacity; the Linux TCP use-after-free study covers an AI-written exploit for a different flaw (**Inferred**).

## Sources

All sources were opened on 11 November 2026. The Intelligence Hub feed was used as an index to the dated press rows and is not cited.

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 1 | N-able status dashboard, incident 202584 "N-central Critical Security Incident" (read from the page's own data) | uptime.n-able.com | 2026-11-11 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 2 | N-able, N-central 2026.4 HF2 release notes (2026-11-10) | status.n-able.com/2026/11/10/n-central-2026-4-hf2-release-notes/ | 2026-11-11 | Confirmed |
| 3 | N-able blog, Update on N-central 2026.4 HF2 and ongoing security response (2026-11-11) | n-able.com/blog/update-on-n-central-2026-4-hf2-and-ongoing-security-response | 2026-11-11 | Confirmed (vendor statements) |
| 4 | CVE record CVE-2026-125883, with CISA ADP SSVC | cve.org/CVERecord?id=CVE-2026-125883 ; cveawg.mitre.org/api/cve/CVE-2026-125883 | 2026-11-11 | Confirmed |
| 5 | CVE record CVE-2026-125881 | cve.org/CVERecord?id=CVE-2026-125881 ; cveawg.mitre.org/api/cve/CVE-2026-125881 | 2026-11-11 | Confirmed |
| 6 | CVE record CVE-2026-125878 | cve.org/CVERecord?id=CVE-2026-125878 ; cveawg.mitre.org/api/cve/CVE-2026-125878 | 2026-11-11 | Confirmed |
| 7 | CVE record CVE-2026-125879, with CISA ADP SSVC | cve.org/CVERecord?id=CVE-2026-125879 ; cveawg.mitre.org/api/cve/CVE-2026-125879 | 2026-11-11 | Confirmed |
| 8 | CVE record CVE-2026-125882 | cve.org/CVERecord?id=CVE-2026-125882 ; cveawg.mitre.org/api/cve/CVE-2026-125882 | 2026-11-11 | Confirmed |
| 9 | CVE record CVE-2026-125880 | cve.org/CVERecord?id=CVE-2026-125880 ; cveawg.mitre.org/api/cve/CVE-2026-125880 | 2026-11-11 | Confirmed |
| 10 | CVE record CVE-2026-91000, with CISA ADP SSVC | cve.org/CVERecord?id=CVE-2026-91000; cveawg.mitre.org/api/cve/CVE-2026-91000 | 2026-11-11 | Confirmed |
| 11 | NVD records CVE-2026-125883 and CVE-2026-125878 | nvd.nist.gov/vuln/detail/CVE-2026-125883; services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-125883 | 2026-11-11 | Confirmed |
| 12 | CISA Known Exploited Vulnerabilities catalog, JSON feed, catalog version 2026.11.10 | cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json | 2026-11-11 | Confirmed |
| 13 | CISA KEV catalog web entries for CVE-2025-8875 and CVE-2026-18577 | cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2025-8875; cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-18577 | 2026-11-11 | Confirmed |
| 14 | Researcher's repository, folder "0-Days/N-Central N-Able": account and repository metadata, commits, file names and README prose only (requested as Oracle-Security/CVEs; served as MSPNightmare/CVEs) | GitHub repository MSPNightmare/CVEs (requested as Oracle-Security/CVEs), folder 0-Days/N-Central N-Able, at `github.com/MSPNightmare/CVEs/tree/main/0-Days/N-Central%20N-Able`; not linked because it holds proof-of-concept code for unfixed flaws | 2026-11-11 | Confirmed (metadata); Reported (README claims) |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 15 | Commit history of the README in Oracle-Security/CVEs (metadata only) | GitHub commit history of 0-Days/N-Central N-Able/README.md in Oracle-Security/CVEs, at `github.com/Oracle-Security/CVEs/commits/main/0-Days/N-Central%20N-Able/README.md`; not linked because the repository holds proof-of-concept code for unfixed flaws | 2026-11-11 | Confirmed |
| 16 | Tenable, Able2Shell: frequently asked questions for reported N-able N-central zero-day vulnerabilities (2026-11-11) | tenable.com/blog/able2shell-frequently-asked-questions-... | 2026-11-11 | Reported (its own Vulnerability Watch ratings Confirmed) |
| 17 | Huntress, N-able disables cloud services following disclosure of Able2Shell exploit chains (2026-11-09, updated 2026-11-10 17:30 ET) | huntress.com/blog/n-able-disables-cloud-services-... | 2026-11-11 | Confirmed (own observations and guidance); Reported (relayed N-able statements) |
| 18 | Beazley Security Labs, BSL-A1242, critical vulnerabilities in N-able N-central (2026-11-09, updated 2026-11-10) | labs.beazley.security/advisories/BSL-A1242 | 2026-11-11 | Reported |
| 19 | Previdian, N-able N-central critical vulnerabilities: what we know so far (2026-11-09, updated 2026-11-10 and 11) | blog.previdian.com/n-able-n-central-critical-vulnerabilities-what-we-know-so-far/ | 2026-11-11 | Demonstrated (decoy telemetry); Confirmed (its own watchlist record) |
| 20 | Field Effect, N-central offline as alleged zero-days surface (2026-11-09, updated 2026-11-10 and 11) | fieldeffect.com/blog/n-central-offline-alleged-zero-days | 2026-11-11 | Confirmed (own statements and advice); Reported (relayed facts) |
| 21 | runZero, N-able N-central Able2Shell vulnerabilities: find impacted installs (updated 2026-11-09 17:50 EST) | runzero.com/blog/n-able-n-central/ | 2026-11-11 | Reported |
| 22 | H-ISAC Threat Bulletin TLP:WHITE, N-able takes N-central offline following disclosure of Able2Shell zero-day exploits (2026-11-10), AHA landing page | aha.org/h-isac-green-reports/2026-11-10-h-isac-threat-bulletin-... | 2026-11-11 | Confirmed |
| 23 | H-ISAC Threat Bulletin TLP:WHITE (2026-11-10), PDF | aha.org/system/files/media/file/2026/11/h-isac-threat-bulletins-...pdf | 2026-11-11 | Confirmed |
| 24 | Cloud Security Alliance, CISO Daily Briefing (2026-11-10) | labs.cloudsecurityalliance.org/research/alt-ciso-briefing-2026-11-10/ | 2026-11-11 | Reported |
| 25 | BleepingComputer, N-able takes cloud platform offline after 30-plus zero-days published (2026-11-09, updated 2026-11-11) | bleepingcomputer.com/news/security/n-able-takes-cloud-platform-offline-... | 2026-11-11 | Reported |
| 26 | BleepingComputer, N-able releases security hotfixes for zero-day vulnerabilities (2026-11-11) | bleepingcomputer.com/news/security/n-able-releases-security-hotfixes-... | 2026-11-11 | Reported |
| 27 | TechTarget, N-able takes N-central platform offline after zero-day dump (2026-11-09) | techtarget.com/news/n-able-takes-n-central-platform-offline-... | 2026-11-11 | Reported |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 28 | GovInfoSecurity, N-able takes platform offline after 33 zero-days drop (2026-11-09) | govinfosecurity.com/n-able-takes-platform-offline-after-33-zero-days-drop-a-33337 | 2026-11-11 | Reported |
| 29 | SecurityWeek, N-able takes N-central offline as researcher drops over 30 zero-days (2026-11-10) | securityweek.com/n-able-takes-n-central-offline-... | 2026-11-11 | Reported |
| 30 | The Hacker News, N-able takes N-central cloud offline after researcher discloses 33 zero-days with PoC exploits (2026-11-10, updated) | thehackernews.com/2026/11/n-able-takes-hosted-n-central-offline.html | 2026-11-11 | Reported |
| 31 | TechCrunch, N-able takes its remote access service offline after researcher publishes dozens of zero-day bugs (2026-11-10) | techcrunch.com/2026/11/10/n-able-takes-its-remote-access-service-offline-... | 2026-11-11 | Reported |
| 32 | CSO Online, N-able N-central gets emergency fix two days after 33 exploits published (2026-11-10) | csoonline.com/article/4247028/... | 2026-11-11 | Reported |
| 33 | Cybersecurity Dive, N-able issues hotfix after researcher dumps PoCs in disclosure spat (2026-11-11) | cybersecuritydive.com/news/n-able-hotfix-researcher-pocs-zero-days/874388/ | 2026-11-11 | Reported |
| 34 | N-able status, announcing the GA of N-central 2025.3.1 (2025-08-13) | status.n-able.com/2025/08/13/announcing-the-ga-of-n-central-2025-3-1/ | 2026-11-11 | Confirmed |
| 35 | N-able status, N-central 2026.3 Hotfix 1, mitigation for CVE-2026-18577 (2026-08-02) | status.n-able.com/2026/08/02/n-central-2026-3-hotfix-1-mitigation-for-cve-2026-18577/ | 2026-11-11 | Confirmed |
| 36 | N-able blog, N-central security update (slug august-2-2026; page dated 10 August 2026) | n-able.com/blog/n-central-security-update-august-2-2026 | 2026-11-11 | Confirmed (vendor account) |
| 37 | N-able blog, N-central security update, August 10, 2026 | n-able.com/blog/n-central-security-update-august-10-2026 | 2026-11-11 | Confirmed (vendor account) |
| 38 | N-able status, N-central 2026.3 Hotfix 4, CVE-2026-86218 (2026-09-06) | status.n-able.com/2026/09/06/n-central-2026-3-hotfix-4-cve-2026-86218/ | 2026-11-11 | Confirmed |
| 39 | N-able blog, take action to apply 2026.3 HF4 (2026-09-05, updated 09-06 and 09-09) | n-able.com/blog/n-central-security-hotfix-september-5-2026 | 2026-11-11 | Confirmed (vendor account) |
| 40 | N-able, N-central 2026.4 release notes (last updated 2026-10-02) | documentation.n-able.com/N-central/Release_Notes/GA/Content/N-central_2026.4_Release_Notes.htm | 2026-11-11 | Confirmed |
| 41 | Canadian Centre for Cyber Security, N-able security advisory AV26-885 (2026-09-08, updated 2026-09-09) | cyber.gc.ca/en/alerts-advisories/n-able-security-advisory-av26-885 | 2026-11-11 | Confirmed |
| 42 | The Hacker News, N-central attackers reach managed systems (2026-08-08) | thehackernews.com/2026/08/n-central-attackers-reach-managed.html | 2026-11-11 | Reported |
| 43 | Help Net Security, on CVE-2026-86218 (2026-09-07) | helpnetsecurity.com/?p=383808 | 2026-11-11 | Reported |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 44 | Kaseya, Important Notice July 2nd 2021 (incident log) | helpdesk.kaseya.com/hc/en-gb/articles/4403440684689-Important-Notice-July-2nd-2021 | 2026-11-11 | Confirmed |
| 45 | CISA, Kaseya VSA ransomware attack (archived, released 2021-07-12) | cisa.gov/uscert/kaseya-ransomware-attack | 2026-11-11 | Confirmed |
| 46 | CISA, Kaseya ransomware attack: guidance for affected MSPs and their customers (2021-07-12) | cisa.gov/news-events/news/kaseya-ransomware-attack-guidance-affected-msps-and-their-customers | 2026-11-11 | Confirmed |
| 47 | DIVD CSIRT, Kaseya limited disclosure (2021-07-07) | csirt.divd.nl/2021/07/07/Kaseya-Limited-Disclosure/ | 2026-11-11 | Confirmed |
| 48 | NVD, CVE-2021-30116 | nvd.nist.gov/vuln/detail/CVE-2021-30116 | 2026-11-11 | Confirmed |
| 49 | ConnectWise, ScreenConnect 23.9.8 security bulletin (2024-02-19, updated 2024-02-20) | connectwise.com/company/trust/security-bulletins/connectwise-screenconnect-23.9.8 | 2026-11-11 | Confirmed |
| 50 | NVD, CVE-2024-1709 | nvd.nist.gov/vuln/detail/CVE-2024-1709 | 2026-11-11 | Confirmed |
| 51 | SimpleHelp, KB: security vulnerabilities 01-2025 | guides.simple-help.com/kb---security-vulnerabilities-01-2025 | 2026-11-11 | Confirmed |
| 52 | NVD, CVE-2024-57727 | nvd.nist.gov/vuln/detail/CVE-2024-57727 | 2026-11-11 | Confirmed |
| 53 | CISA, AA25-163A, ransomware actors exploit unpatched SimpleHelp RMM (2025-06-12) | cisa.gov/news-events/cybersecurity-advisories/aa25-163a | 2026-11-11 | Confirmed |
| 54 | Sophos, DragonForce actors target SimpleHelp vulnerabilities to attack MSP customers (undated page; listed 2025-05-27) | sophos.com/en-us/blog/dragonforce-actors-target-simplehelp-vulnerabilities-... | 2026-11-11 | Reported |
| 55 | CISA and Five Eyes partners, AA22-131A, protecting against cyber threats to managed service providers and their customers (2022-05-11) | cisa.gov/news-events/cybersecurity-advisories/aa22-131a | 2026-11-11 | Confirmed |
| 56 | CISA, NSA and MS-ISAC, AA23-025A, protecting against malicious use of remote monitoring and management software (2023-01-25) | cisa.gov/news-events/cybersecurity-advisories/aa23-025a | 2026-11-11 | Confirmed |
| 57 | MITRE ATT&CK, live technique pages (T1190, T1219, T1078, T1136, T1059, T1068, T1199, T1072, T1595.002), site at v20.1 | attack.mitre.org/techniques/T1219/ (and the same path for each id) | 2026-11-11 | Confirmed |
| 58 | TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `technique_to_d3fend.jsonl`, `d3fend_countermeasures.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `data/weaknesses/cwe.jsonl` and `capec.jsonl`, and the `mitre/` tree | github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack | 2026-11-11 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 59 | TeamStarWolf, Chronicle 2021 case study (Kaseya VSA home study) | /case-studies/CHRONICLE_2021.md | 2026-11-11 | Confirmed (as the library's record) |
| 60 | CISA, Known Exploited Vulnerabilities Catalog (criteria for active exploitation) | cisa.gov/known-exploited-vulnerabilities | 2026-11-11 | Confirmed |
| 61 | NVD, CVE-2025-8875 (CNA weakness CWE-502; CNA CVSS v4.0 9.4) | nvd.nist.gov/vuln/detail/CVE-2025-8875 | 2026-11-11 | Confirmed |
| 62 | NVD, CVE-2025-8876 (CNA weakness CWE-20, NVD weakness CWE-78; CNA CVSS v4.0 9.4) | nvd.nist.gov/vuln/detail/CVE-2025-8876 | 2026-11-11 | Confirmed |

*© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.*

*© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/*

*© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/*

*© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/*

*The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.*

## Related references

- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents: no actor or malware family is attributed to Able2Shell
- Vulnerability Prioritization Reference, Vulnerability Management Reference, Triage a CVE
- Supply Chain Security Reference
- Related studies: Chronicle 2021, the home study for Kaseya VSA; SolarWinds and SUNBURST, one trusted IT management product turned against its customers; The Ransomware Ecosystem, which covers the Kaseya VSA attack, ScreenConnect CVE-2024-1709, SimpleHelp CVE-2024-57727, DragonForce, Black Basta and Medusa; AI Threats 2026, on AI-assisted vulnerability discovery; the Linux TCP use-after-free, where severity and KEV status diverged
- Groups: G0115 GOLD SOUTHFIELD (Kaseya context only)
- Software: S0496 REvil (Kaseya context only), S0591 ConnectWise (ScreenConnect)
- Techniques: T1595.002 Vulnerability Scanning, T1190 Exploit Public-Facing Application, T1068 Exploitation for Privilege Escalation, T1059 Command and Scripting Interpreter, T1136 Create Account, T1219 Remote Access Tools, T1572 Protocol Tunneling, T1543.003 Windows Service, T1078 Valid Accounts, T1072 Software Deployment Tools, T1199 Trusted Relationship, T1486 Data Encrypted for Impact, T1552.001 Credentials In Files
- CAPEC: CAPEC-146, CAPEC-221, CAPEC-664, CAPEC-240, CAPEC-233, CAPEC-126, CAPEC-63

- D3FEND: Software Update, Inbound Traffic Filtering, Network Traffic Filtering, Remote Terminal Session Detection, User Account Permissions, Credential Rotation, Multi-factor Authentication, all countermeasures
- Navigator layers, including this study's layer, nable-ncentral-able2shell-2026.json
- All case studies